IE3142 · DEVOPS SECURITY

Continuous Monitoring & Incident Response

Lecture 07 — Security monitoring, log management, IDS/IPS, incident response, and digital forensics

LECTURE ROADMAP

Topics Covered

1
Security Monitoring & Log Management
Observing systems, collecting logs, SIEM.

2
Intrusion Detection & Prevention (IDS/IPS)
Detecting and stopping malicious activity.

3
Incident Response Planning & Execution
Preparing for and handling security incidents.

4
Security Incident Investigation & Forensics
Reconstructing attacks and preserving evidence.

PART 1

Introduction to Continuous Monitoring and Incident Response

Why security does not stop at deployment

Why Do We Need Continuous Security Monitoring?

Security does not end when an application is successfully deployed.

Even if an application has passed:

- SAST
- SCA
- DAST
- Container scanning
- Security configuration checks

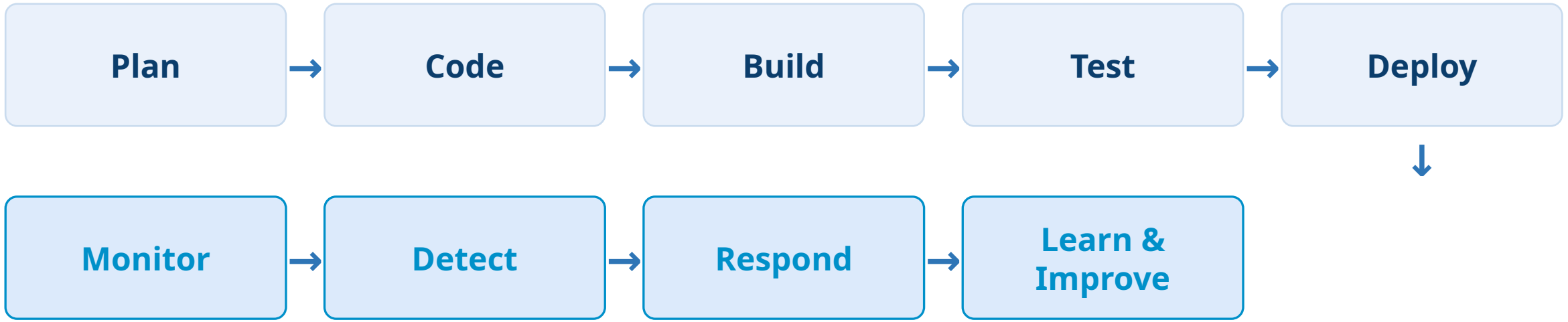
New threats can still occur after deployment:

- Stolen credentials
- Malware infections
- Insider threats
- Unauthorized login attempts
- Privilege escalation
- Attacks against APIs

Continuous monitoring provides ongoing visibility into applications, infrastructure, networks, and security events, so suspicious activity can be detected and answered quickly.

CONTINUOUS MONITORING

Security After Deployment



A traditional view treats Deploy as the end. DevSecOps instead loops back, findings from Monitor, Detect, Respond, and Learn & Improve feed into Development, creating a continuous security feedback loop.

What is Continuous Security Monitoring?

Continuous Security Monitoring (CSM) is the ongoing observation and analysis of applications, infrastructure, networks, identities, configurations, and security events to identify threats, vulnerabilities, and incidents continuously, rather than occasionally.

Continuous Monitoring Can Observe

- User activities
- Network traffic
- System processes
- API requests
- Container activities
- Login attempts
- Application behavior
- Cloud activities
- Configuration changes
- File modifications

Main Objectives

- Detect threats early
- Identify abnormal activities
- Provide real-time / near-real-time alerts
- Support incident response
- Reduce time attackers remain undetected
- Maintain visibility of production

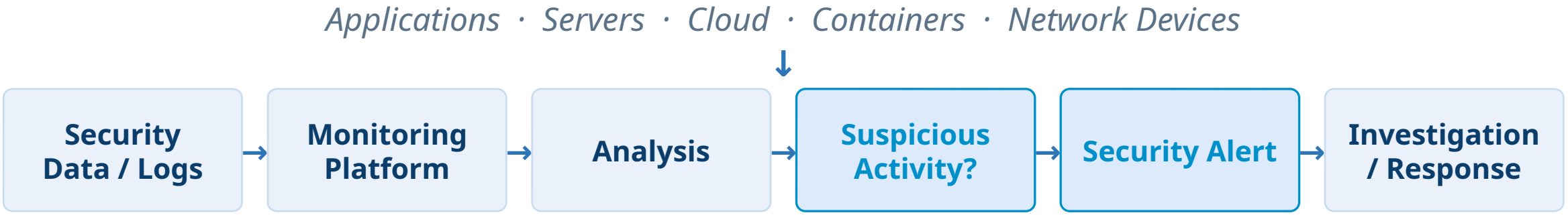
PART 2

Security Monitoring and Log Management in DevSecOps

From raw data to actionable alerts

What is Security Monitoring?

Security monitoring is the process of continuously observing systems and analyzing security-related information to identify potential attacks, policy violations, vulnerabilities, and abnormal activities.



Monitoring allows security teams to understand what is currently happening within the environment.

What Should We Monitor?

Area	Examples of Information to Monitor
Application	Errors, authentication events, API requests
Server	Processes, CPU usage, file changes, login attempts
Network	Connections, traffic patterns, blocked requests
Cloud	IAM activity, API calls, configuration changes
Containers	Container creation, execution, suspicious processes
Kubernetes	Pod activity, API requests, RBAC changes
Database	Login attempts, queries, administrative changes
IAM	Failed logins, privilege changes, MFA events

What is a Log?

A log is a record of an event or activity that occurred within a system, application, device, or service.

A Log Entry May Contain

- Timestamp
- Source IP address
- Resource accessed
- Success / failure status
- User / account
- Event type
- Action performed
- Error information

Logs become valuable when they are collected and analyzed together.

Example Log Entry

```
2026-08-24 10:35:21   User: admin
Source IP: 203.0.113.25
Action: Login
Status: FAILED
```

One failed login may be normal. But a rapid sequence may indicate a brute-force attack:

```
10:35:21  FAILED
10:35:23  FAILED
10:35:25  FAILED
10:35:27  FAILED
10:35:29  FAILED
```

Types of Security Logs

1

Application Logs

User activities, application errors, authentication events, API activities.

2

Operating System Logs

Login/logout, process execution, privilege changes, system errors.

3

Network Logs

Firewall activity, network connections, IDS/IPS alerts.

4

Cloud Audit Logs

Resource creation/deletion, IAM changes, administrative actions, API calls.

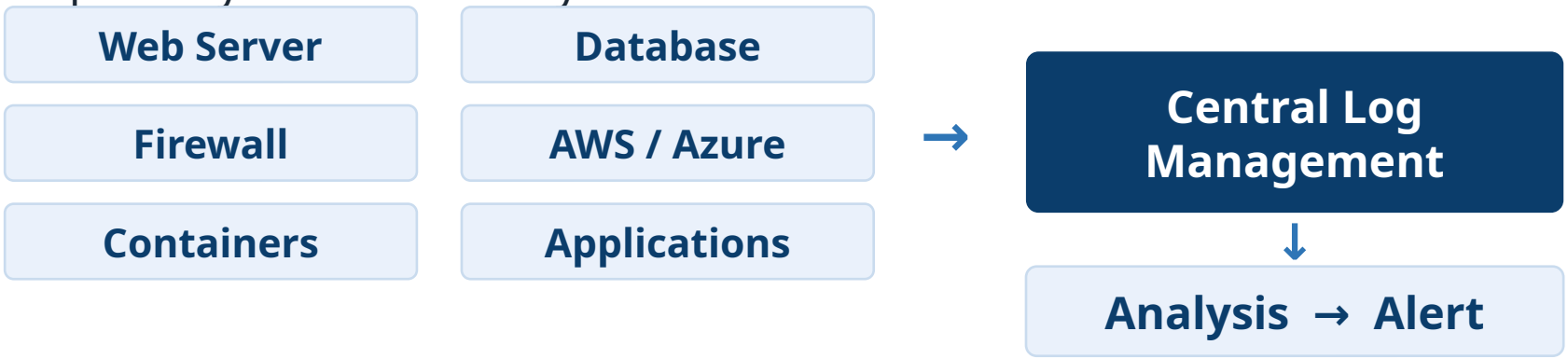
5

Container / Kubernetes Logs

Container activity, pod events, Kubernetes API activity.

Log Management

Log management is the process of collecting, centralizing, storing, protecting, analyzing, and retaining logs generated by different systems. A centralized approach is preferable to keeping logs separately on individual systems.



Benefits

- Centralized visibility
- Easier threat detection
- Compliance support
- Faster investigation
- Audit trail preservation
- Event correlation

Logs must be protected against unauthorized deletion or modification attackers may try to remove evidence of their activities.

Security Information and Event Management (SIEM)

A SIEM platform collects and analyzes security information from multiple systems to identify suspicious patterns and generate alerts.



Example — correlation reveals what individual events cannot

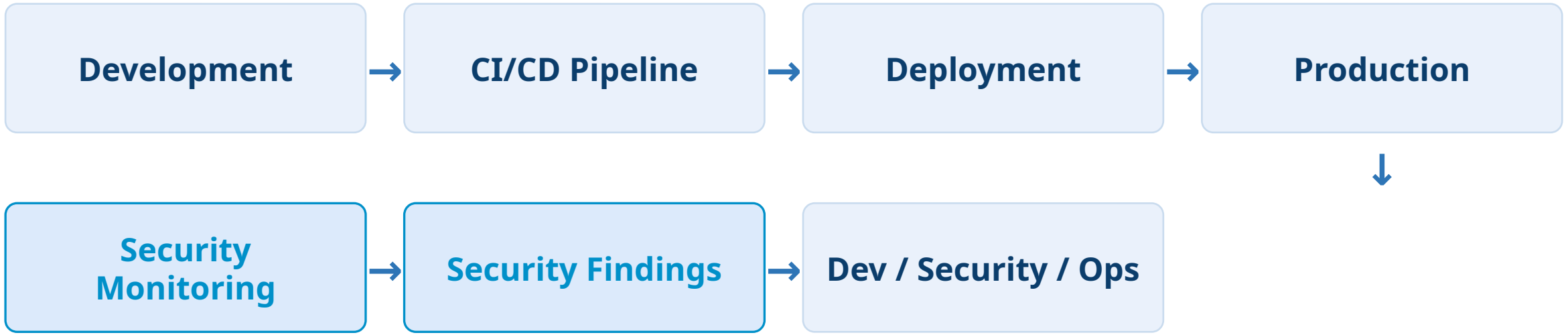


Individually, these events may look harmless. Correlated together, they may indicate account compromise.

Example SIEM Platforms

Microsoft Sentinel · Splunk · IBM QRadar · Elastic Security

Monitoring in DevSecOps



Example: if runtime monitoring repeatedly detects attacks against a particular API endpoint, that information returns to developers so the API's security controls can be improved. This is sometimes called "shifting right" using production feedback to continuously improve security.

PART 3

Intrusion Detection and Prevention Systems

Detecting — and stopping — malicious activity

What is an Intrusion?

An intrusion is an unauthorized or malicious activity that attempts to compromise a system, network, or application.

- Unauthorized network access
- Port scanning
- Exploitation of vulnerabilities
- Attempts to access restricted resources
- Malware communication
- Brute-force login attempts
- Suspicious network traffic

Security monitoring should identify these activities as early as possible.

Intrusion Detection System (IDS)

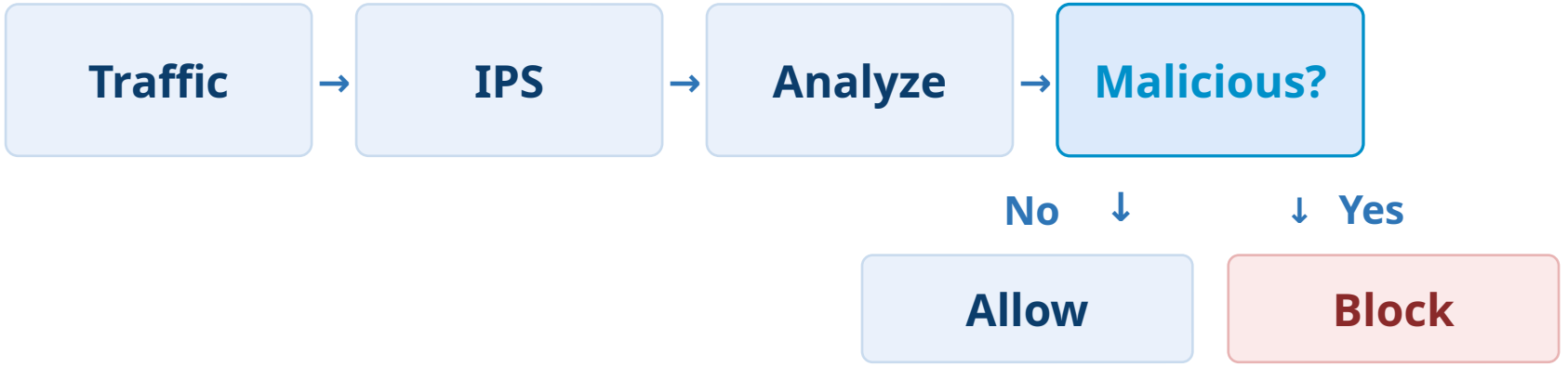
An IDS monitors network or system activity to identify suspicious behavior or known attack patterns. When malicious activity is identified, the IDS generates an alert.



Key characteristic: IDS detects and alerts, but normally does not automatically block the traffic.

Intrusion Prevention System (IPS)

An IPS monitors network traffic and can automatically take action when malicious activity is detected.



An IPS May

- Drop malicious packets
- Block a connection
- Block an IP address
- Reset a connection
- Generate an alert

IDS vs IPS

IDS	IPS
Intrusion Detection System	Intrusion Prevention System
Detects malicious activity	Detects and prevents malicious activity
Primarily generates alerts	Can automatically block attacks
Usually passive	Active / in-line control
Does not normally interrupt traffic	Can interrupt malicious traffic

Easy Way to Remember

IDS = Security Alarm
It detects someone entering and raises an alarm.

IPS = Security Guard
It detects the intruder and attempts to stop them.

IDS/IPS Detection Techniques

Signature-Based Detection

- Compares activities against known attack patterns or signatures.
- Advantage: Effective against known attacks; generally lower false positives for well-defined signatures.
- Limitation: May fail to identify new or unknown attacks.

Anomaly-Based Detection

- Creates a baseline of normal behavior and identifies significant deviations.
- Advantage: Can identify previously unknown or unusual attacks.
- Limitation: May produce more false positives; requires understanding of normal behavior.

PART 4

Incident Response Planning and Execution

Preparing for, and acting during, a security incident

What is a Security Incident?

Security Event
An observable occurrence within a system or network.

Security Incident
An event, or group of events, that actually or potentially compromises security or violates policy.

Examples of Security Incidents

- Successful unauthorized access
- Compromised cloud account
- Malware infection
- Unauthorized privilege escalation
- Ransomware
- Compromised container
- Data breach
- Denial-of-Service attack

Not every security event becomes a security incident.

What is Incident Response?

Incident Response (IR) is the organized process used by an organization to prepare for, detect, analyze, contain, eradicate, and recover from cybersecurity incidents.

Main Objectives

- Limit damage
- Restore normal operations
- Prevent recurrence
- Stop ongoing attacks
- Preserve evidence
- Protect affected assets
- Determine the root cause

Without an incident response plan, organizations may respond slowly or inconsistently during an attack.

Incident Response Lifecycle

1

1. Preparation

IR plan, roles, communication procedures, monitoring, backups, security tools.

2

2. Detection & Analysis

Analyze alerts, review logs, determine affected systems and severity.

3

3. Containment

Isolate compromised machine/container, disable account, block malicious IP.

4

4. Eradication

Remove malware, patch vulnerability, delete malicious accounts, fix config.

5

5. Recovery

Restore from clean backups, reconnect systems, monitor for further attacks.

6

6. Lessons Learned

Review the incident and improve security controls.

Incident Response Roles and Responsibilities

- **Incident Response Team —** Coordinates the response.
- **Security Analysts —** Investigate alerts and evidence.
- **System / Cloud Administrators —** Isolate and restore infrastructure.
- **Developers / DevOps Engineers —** Fix application and pipeline issues.
- **Management —** Makes business-level decisions.
- **Legal / Compliance Teams —** Address regulatory and reporting requirements.
- **Communication Team —** Manages internal / external communication where required.

DevSecOps improves incident response because developers, operations personnel, and security specialists collaborate rather than operating as completely separate teams.

PART 5

Security Incident Investigation and Digital Forensics

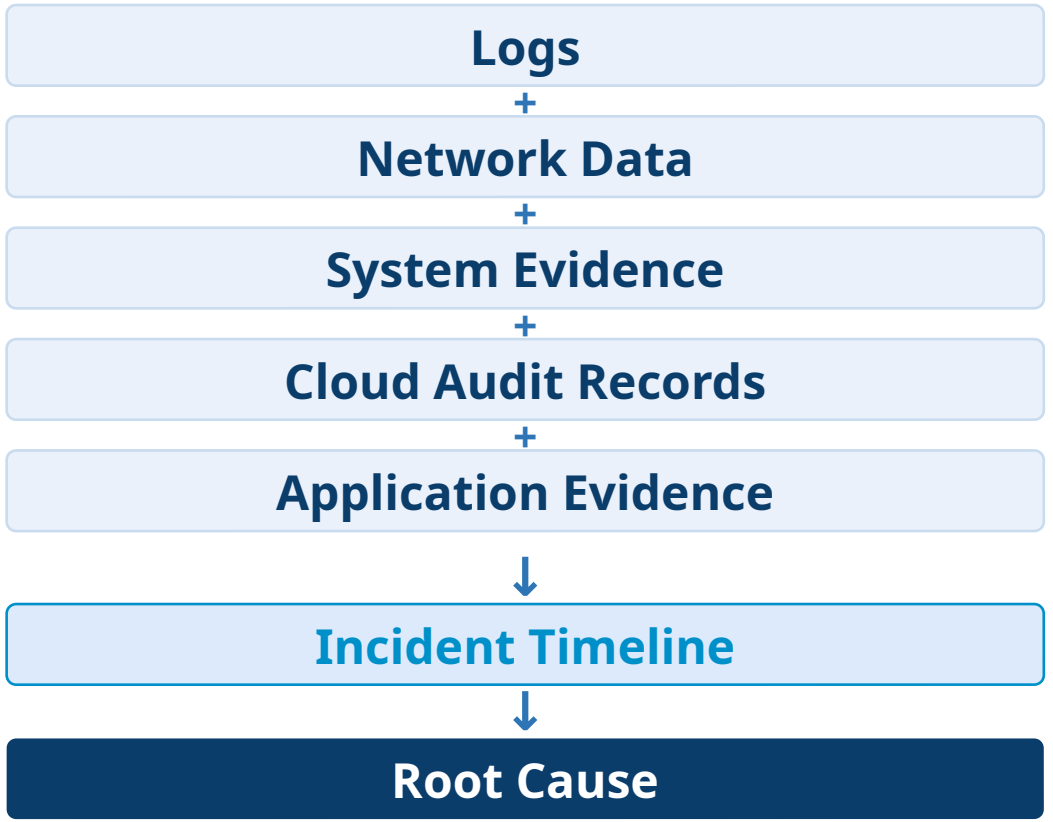
Reconstructing what happened, and proving it

Security Incident Investigation

Incident investigation attempts to determine:

- What happened?
- When did it happen?
- How did the attacker gain access?
- Which systems were affected?
- Which accounts were compromised?
- What actions did the attacker perform?
- Was data accessed or stolen?
- Is the attacker still present?
- What vulnerability caused the incident?

Reconstructing the Attack



INVESTIGATION

Digital Forensics

Digital forensics is the systematic process of identifying, collecting, preserving, examining, analyzing, and reporting digital evidence related to a security incident.

Possible Evidence

- System logs
- Application logs
- Network captures
- Files
- Memory
- Disk images
- Emails
- Cloud audit logs
- Authentication records
- Container logs

Digital evidence should be handled carefully, improper handling can modify or destroy important evidence.

INVESTIGATION

Basic Digital Forensics Process

1. **Identification**
   Identify potential sources of evidence.

2. **Collection**
   Acquire relevant digital evidence.

3. **Preservation**
   Protect evidence against modification or destruction.

4. **Examination**
   Extract relevant information.

5. **Analysis**
   Determine what occurred and reconstruct the sequence of events.

6. **Reporting**
   Document findings, methods, evidence, and conclusions.

Chain of Custody

Chain of Custody is the documented record showing how digital evidence was collected, handled, transferred, stored, and analyzed. It helps demonstrate that evidence has not been improperly altered.

A Chain-of-Custody Record May Contain

- Description of evidence
- Evidence identifier
- Date and time collected
- Transfers between individuals
- Person who collected it
- Storage information
- Collection location / source
- Actions performed on the evidence

Why is it important? Without proper evidence handling, it may be difficult to demonstrate the integrity and reliability of digital evidence, particularly when an incident leads to legal or disciplinary proceedings.

INVESTIGATION

Using Logs for Incident Investigation

Logs are one of the most important sources of evidence during incident investigation.

```
09:01  Multiple failed login attempts
09:06  Successful login from unusual IP
09:08  Privilege changed to Administrator
09:12  Database accessed
09:15  Large amount of data downloaded
09:18  Account logged out
```

Correlating these records builds an incident timeline:

Credential Attack

↓

Account Compromise

↓

Privilege Escalation

↓

Database Access

↓

Possible Data Exfiltration

This shows why continuous monitoring, good logging, incident response, and forensics are closely connected.

Continuous Monitoring and Incident Response in DevSecOps



An incident should not simply be fixed and forgotten. Findings feed back into secure coding, threat models, CI/CD security controls, cloud configuration, container security, IAM policies, monitoring rules, and security tests — creating continuous security improvement.

KEY TAKEAWAYS

Monitoring, Response & Forensics

Continuous Monitoring

- Security doesn't end at deployment
- CSM gives ongoing visibility
- Logs are the raw evidence
- Log management + SIEM centralize & correlate
- IDS alerts, IPS can block

Incident Response

- Not every event is an incident
- Prepare, detect, contain, eradicate, recover, learn
- Clear roles and responsibilities matter
- DevSecOps improves IR through collaboration

Investigation & Forensics

- Investigation reconstructs the attack timeline
- Digital forensics preserves & analyzes evidence
- Chain of custody protects evidence integrity
- Findings feed back into CI/CD for improvement

DEVSECOPS

An incident is not fixed and forgotten, it feeds back into continuous security improvement.

Thank you · Questions?